

Browse > Hands-on Labs > **Lab 03: Artifacts** 3 of 14 in Hands-on Labs

Prereq: Lab 02: Build & Test Artifact Management

Up next in Hands-on Labs →

**Lab 04: Deployment**

 Hands-on lab · 45 min · Env: Docker + GHCR · Overview & prereqs · Download PDF ·

Reset checks

CI/CD ENGINEERING · KNOWLEDGE BASE

# Lab 03: Artifacts

CICD BY Nabawy

Reader editionNabawy

# Objective

Build a Docker image once, tag it by commit SHA, push to GHCR, attach an SBOM — then prove staging and prod would run the same digest.

## Prerequisites

- Lab 02 green; a Dockerfile (multi-stage, node:20-slim runtime); concepts: Artifact Management.

## Architecture

Merge to main → build image → tag ghcr.io/<you>/<app>:sha-<short> → push GHCR → generate SBOM → print digest (the deployable identity).

## Setup

Enable GitHub Packages (GHCR) on the repo; workflow needs packages: write permission.

## Step 1 — Build once, tag SHA

## Execute

```
jobs: image: runs-on: ubuntu-latest permissions: { packages: write } steps: - uses: actions/checkout@v4 - uses: docker/login-action@v3 with: { registry: ghcr.io, username: ${{ github.actor }}, password: ${{ secrets.GITHUB_TOKEN }} } - uses: docker/metadata-action@v5 id: meta with: images: ghcr.io/${{ github.repository }} tags: type=sha,prefix=sha- - uses: docker/build-push-action@v6 with: { push: true, tags: ${{ steps.meta.outputs.tags }} }
```

## Expected Result

GHCR shows sha-<short> tag; logs print the digest.

## Why

SHA tag = immutable identity; the digest (not :latest) is what every environment deploys (see versioning).

## Step 2 — Attach SBOM

### Execute

Add after push: `anchore/sbom-action@v0` on the pushed image; inspect the artifact.

### Expected Result

SBOM artifact lists every package inside the image.

# Why

The ingredient list that makes the next CVE answerable in minutes, not days.

## Verification

- [ ] GHCR holds an immutable SHA tag.
- [ ] Same digest referenced twice = same bytes.
- [ ] SBOM artifact present.

## Failure Scenarios

- 403 on push: missing packages: write — add the permission block.
- latest deployed somewhere: retag nothing; fix consumers to pin the digest.

## Cleanup

Keep images; they are small and prove immutability.

## What This Proved

Build-once identity, SHA discipline, SBOM habit. Continue with Lab 04.

## Interview Notes

- Digest vs tag: why redeploying latest can silently change what's running.
- The 403 on push — which single permission block fixes it and why least privilege demands it.

Up next in Hands-on Labs →

Lab 04: Deployment

### RELATED BOOKS



Lab 04: Deployment

60 min · INT



Lab 02: Build & Test

45 min · INT

→ Next in path

→ Previous in path



## Lab 01: First Pipeline

45 min · **BEG**

→ Same path



## Lab 01: GitHub Webhook Trigger for Jenkins

45 min · **INT**

→ Same path